

Avaliação Intermediária

Endpoint Investigator

Professor Rodolfo Avelino – Tecnologias Hackers

Objetivo da Atividade

Esta avaliação tem como objetivo orientar o desenvolvimento de uma ferramenta de investigação de segurança para sistemas GNU/Linux, denominada Endpoint Investigator. A proposta busca consolidar os conceitos trabalhados nas primeiras aulas da disciplina, principalmente processos, identidade, privilégios, permissões, serviços e registros do sistema operacional.

A ferramenta não precisa ser um antivírus ou uma solução completa de Endpoint Detection and Response (EDR). O objetivo é construir uma solução capaz de coletar, relacionar e interpretar informações de um endpoint Linux, auxiliando um analista na identificação de configurações ou comportamentos que mereçam investigação.

Ideia Central:

Uma evidência isolada raramente é suficiente para caracterizar um incidente. A ferramenta deve ajudar o analista a observar, correlacionar evidências, formular hipóteses e explicar o que ainda não pode ser concluído.

Por meio desta atividade, o que se espera:

- Aplicar conceitos de processos, PID/PPID, usuários e privilégios na análise de um sistema Linux.
- Analisar permissões de arquivos e diretórios associados a processos e serviços.
- Identificar serviços em execução e relacioná-los aos processos, usuários e recursos utilizados.
- Correlacionar diferentes evidências do sistema operacional para identificar situações que mereçam investigação. Por exemplo, um processo suspeito que está gerenciando uma porta de comunicação.
- Desenvolver uma solução automatizada para coleta e análise dessas informações.

A solução

Cada grupo deverá desenvolver uma ferramenta que deverá analisar obrigatoriamente três dimensões: processos, permissões e serviços.

Outras fontes de informação poderão ser incorporadas, desde que tenham relação clara com a estratégia de investigação definida pelo grupo.

- logs
- conexões de rede
- usuários e grupos
- arquivos abertos
- eventos do systemd (ex: detectar logs suspeitos no syslog)
- hashes de arquivos
- mecanismos de inicialização e persistência

Funcionamento esperado

A solução poderá ser executada sob demanda, realizando um snapshot do estado do sistema no momento da análise. Não é necessário desenvolver um agente permanente.

FLUXO DE REFERÊNCIA

COLETA → NORMALIZAÇÃO → CORRELAÇÃO → EVIDÊNCIAS → HIPÓTESES → RESULTADO DA INVESTIGAÇÃO

A tecnologia, linguagem de programação e arquitetura ficam a critério do grupo. O projeto será avaliado pelo funcionamento e pela qualidade da investigação, e não pela utilização de uma tecnologia específica.

Processos

A ferramenta deverá coletar e analisar informações sobre processos em execução. Poderão ser utilizadas informações como PID, PPID, usuário, UID/GID, comando, argumentos, executável, processo pai, estado e recursos relacionados.

A solução não deverá simplesmente reproduzir a saída de ferramentas como ps. Espera-se que as informações sejam utilizadas na construção de relações, por exemplo entre processo, identidade, processo pai, arquivo e serviço.

ATENÇÃO

O nome de um processo isoladamente não é evidência suficiente para classificá-lo como malicioso. A solução deverá apresentar o contexto utilizado para gerar um finding.

Permissões

A ferramenta deverá analisar permissões de arquivos ou diretórios relevantes para os processos e serviços identificados. A análise deverá ser orientada pelo contexto, e não necessariamente por uma varredura indiscriminada de todo o filesystem.

Considere, por exemplo, a relação entre um serviço executado como root e um script utilizado por esse serviço. O risco está na combinação entre identidade privilegiada, recurso utilizado e capacidade de modificação do recurso.

EXEMPLO DE RACIOCÍNIO

SERVIÇO → executa como root → utiliza script → script pode ser alterado por usuário não privilegiado → possível relação de privilégio insegura. Isso não prova exploração.

Serviços

A solução deverá identificar serviços relevantes em execução no sistema e relacioná-los aos processos e recursos utilizados. Podem ser analisados nome, estado, usuário, grupo, comando de inicialização, executável, scripts e processos associados.

Um serviço executado como root não deverá ser automaticamente classificado como vulnerável. O objetivo é analisar o contexto no qual o privilégio é utilizado.

Correlação das evidências

A solução deverá implementar pelo menos duas formas de correlação entre diferentes fontes de informação. Processos, permissões e serviços não deverão ser tratados apenas como listas independentes.

- Processo + serviço + permissão → hipótese de risco
- Processo + PPID + usuário → contexto de execução
- Serviço + arquivo + usuário → relação de privilégio
- Processo + serviço + log → possibilidade de reconstrução temporal

Os grupos poderão propor outras correlações, desde que consigam justificar sua relevância para uma investigação de segurança.

Evidência, interpretação e hipótese

Os resultados apresentados pela ferramenta deverão distinguir, sempre que possível, aquilo que foi efetivamente observado daquilo que é interpretação e daquilo que permanece como hipótese.

Elemento	Descrição
Evidência	Informação efetivamente observada no sistema.
Interpretação	Significado técnico atribuído à evidência.
Hipótese	Possível explicação para a relação encontrada.
Evidência ausente	Informação adicional necessária para confirmar ou rejeitar a hipótese.

Dados para desenvolvimento e testes

Os grupos receberão conjuntos de dados de treinamento para auxiliar no desenvolvimento e nos testes da solução. Os datasets poderão conter comportamentos normais, configurações inadequadas, configurações legítimas e situações que mereçam investigação. A presença de uma informação no dataset não significa, por si só, que ela representa uma vulnerabilidade. Os grupos deverão construir suas análises a partir das relações entre as diferentes evidências disponíveis.

Como apoio, está disponível no Black Board um script para geração de alguns artefatos e cenários de teste, permitindo que os grupos produzam diferentes conjuntos de dados durante o desenvolvimento. O script fornecido deve ser entendido como um ponto de partida e poderá ser estudado, adaptado e ampliado pelos grupos, inclusive para gerar novos tipos de artefatos, situações e combinações de evidências que permitam testar melhor a solução desenvolvida.

TESTES LOCAIS

Também será possível utilizar a própria VM Kali para criar situações controladas e validar a solução. O objetivo é testar a lógica da ferramenta, não produzir um incidente real.

Uso de Inteligência Artificial

O uso de ferramentas de Inteligência Artificial é permitido durante o desenvolvimento. A IA poderá ser utilizada para apoio à programação, documentação, interpretação de evidências, geração de hipóteses e explicação dos resultados.

Caso a solução incorpore um modelo de linguagem, a IA não deverá ser a única camada de análise. A solução deverá possuir mecanismos próprios de coleta, processamento ou correlação.

NÃO É SUFICIENTE

DADOS → LLM → "Analise esta máquina". A ferramenta deverá produzir evidências estruturadas antes de qualquer interpretação feita por um modelo.

Limitações da solução

A ferramenta não precisa identificar todos os possíveis problemas de segurança existentes em um endpoint. Cada grupo deverá definir claramente o escopo adotado e indicar situações nas quais a solução pode produzir falsos positivos, interpretações incompletas ou resultados inconclusivos.

Uma boa ferramenta de investigação deve reconhecer quando não existem evidências suficientes para uma conclusão.

Entregáveis

- Código-fonte completo da solução.
- README com arquitetura, dependências, instalação, execução, fontes de informação, correlações implementadas e limitações.
- Documento técnico de até quatro páginas, contendo problema, estratégia de investigação, arquitetura, principais correlações, decisões técnicas, uso de IA (quando aplicável) e limitações.
- Demonstração prática da solução funcionando sobre um ambiente ou dataset de teste.

Prazo

A atividade deverá ser desenvolvida em grupo e apresentado em aula no dia 6 de outubro, em ordem indicada pelo professor.

Critérios de Avaliação

Funcionamento da solução 3,0 pontos

Aplicação dos conceitos de processos, permissões e serviços 2,0 pontos

Correlação entre diferentes evidências 2,0 pontos

Qualidade da análise e distinção entre evidência, interpretação e hipótese 1,5 pontos

Arquitetura, código e documentação 1,0 pontos

Demonstração e domínio técnico do grupo 0,5 pontos

Total: 10,0 pontos

Orientação final

OBJETIVO DA AVALIAÇÃO

O objetivo não é encontrar o maior número possível de "vulnerabilidades". O objetivo é demonstrar capacidade de observar, coletar, relacionar evidências, formular hipóteses e justificar conclusões.